

Relazione di Laboratorio – Attacco Brute Force SSH su Metasploitable

Corso: Cybersecurity Analyst

Modulo: W6D4 (Pratica)

Piattaforma: Epicode

Studente: Nouman Javed Nizami

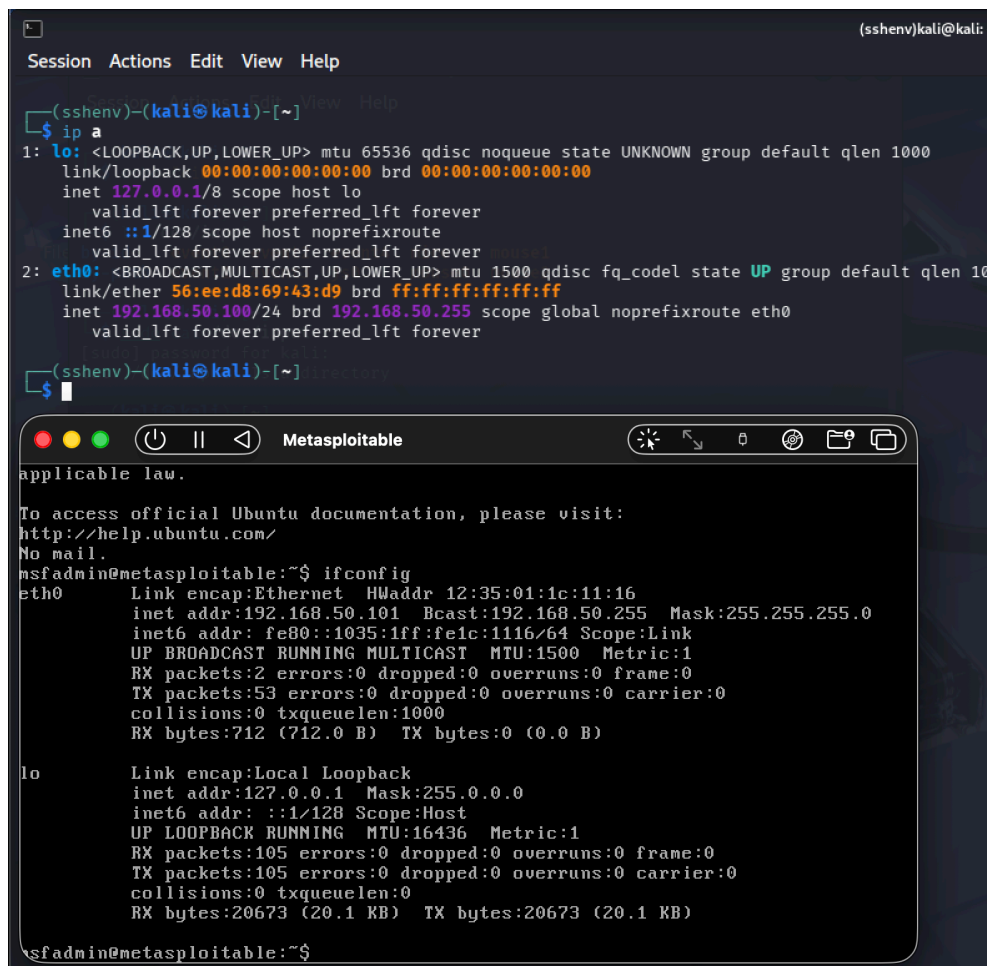
Data: 13/02/2026

1. Introduzione e Obiettivo

L'obiettivo di questo laboratorio è comprendere il funzionamento di un attacco di tipo brute force contro un servizio SSH. L'attività è stata svolta in un ambiente controllato composto da Kali Linux come macchina attaccante e Metasploitable come macchina vulnerabile. Lo scopo non è stato quello di compromettere un sistema reale, ma di analizzare la logica dell'attacco e comprenderne le implicazioni di sicurezza.

2. Descrizione dell'Ambiente di Laboratorio

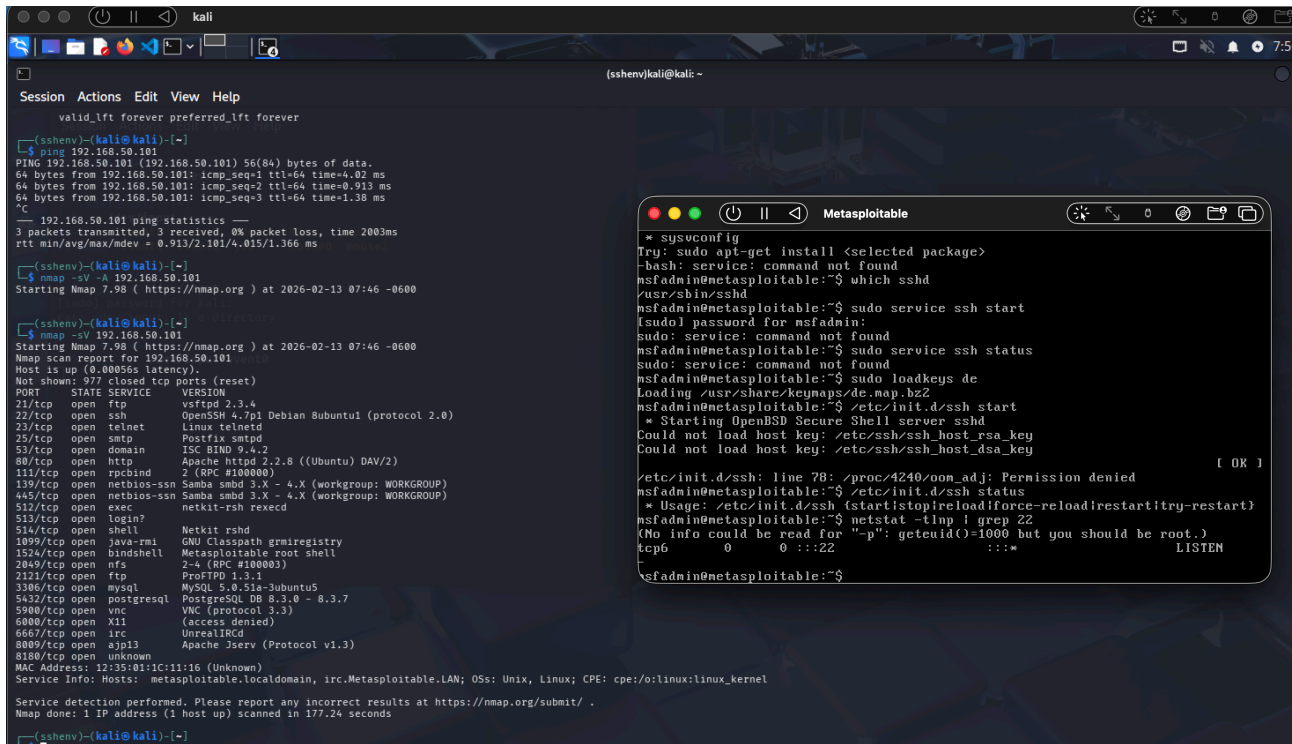
Macchina Attaccante: Kali Linux (IP: 192.168.50.100) Macchina Vittima: Metasploitable (IP:192.168.50.101) Rete: 192.168.50.0/24 (rete interna di laboratorio)



```
(sshenv)kali@kali: ~  
Session Actions Edit View Help  
(sshenv)-(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 56:ee:d8:69:43:d9 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth0  
        valid_lft forever preferred_lft forever  
(sshenv)-(kali@kali)-[~]  
$  
Metasploitable  
applicable law.  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
msfadmin@metasploitable:~$ ifconfig  
eth0      Link encap:Ethernet  HWaddr 12:35:01:1c:11:16  
          inet addr:192.168.50.101  Bcast:192.168.50.255  Mask:255.255.255.0  
          inet6 addr: fe80::1035:1ff:fe1c:1116/64 Scope:Link  
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1  
          RX packets:2 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:53 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:1000  
          RX bytes:712 (712.0 B)  TX bytes:0 (0.0 B)  
  
lo        Link encap:Local Loopback  
          inet addr:127.0.0.1  Mask:255.0.0.0  
          inet6 addr: ::1/128 Scope:Host  
          UP LOOPBACK RUNNING  MTU:16436  Metric:1  
          RX packets:105 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:105 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:0  
          RX bytes:20673 (20.1 KB)  TX bytes:20673 (20.1 KB)  
msfadmin@metasploitable:~$
```

3. Verifica del Servizio SSH

È stato verificato che il servizio SSH fosse attivo sulla macchina Metasploitable e in ascolto sulla porta 22. La verifica è stata effettuata tramite scansione Nmap e successivo tentativo di connessione manuale via SSH.



```
valid_lft forever preferred_lft forever

(ssshenv)-(kali@kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=4.02 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=0.913 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=1.38 ms
^C
--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/ndev = 0.913/2.101/4.015/1.366 ms

(ssshenv)-(kali@kali)-[~]
└─$ nmap -sV -A 192.168.50.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-13 07:46 -0600

(ssshenv)-(kali@kali)-[~]
└─$ nmap -sV 192.168.50.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-13 07:46 -0600
Nmap scan report for 192.168.50.101
Host is up (0.00056s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 5ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath gmrregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8080/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  unknown
MAC Address: 12:35:01:1C:11:16 (Unknown)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 177.24 seconds

(ssshenv)-(kali@kali)-[~]
```

```
* sysconfig
Try: sudo apt-get install <selected package>
-bash: service: command not found
msfadmin@metasploitable:~$ which sshd
/usr/sbin/sshd
msfadmin@metasploitable:~$ sudo service ssh start
[sudo] password for msfadmin:
sudo: service: command not found
msfadmin@metasploitable:~$ sudo service ssh status
sudo: service: command not found
msfadmin@metasploitable:~$ sudo loadkeys de
Loading /usr/share/keymaps/de.map.bz2
msfadmin@metasploitable:~$ /etc/init.d/ssh start
* Starting OpenBSD Secure Shell server sshd
Could not load host key: /etc/ssh/ssh_host_rsa_key
Could not load host key: /etc/ssh/ssh_host_dsa_key
[ OK ]
/etc/init.d/ssh: line 78: /proc/4240/oom_adj: Permission denied
msfadmin@metasploitable:~$ /etc/init.d/ssh status
* Usage: /etc/init.d/ssh {start|stop|reload|force-reload|restart|try-restart}
msfadmin@metasploitable:~$ netstat -tlnp | grep 22
tcp6      0      0 :::22                :::*                  LISTEN
msfadmin@metasploitable:~$
```

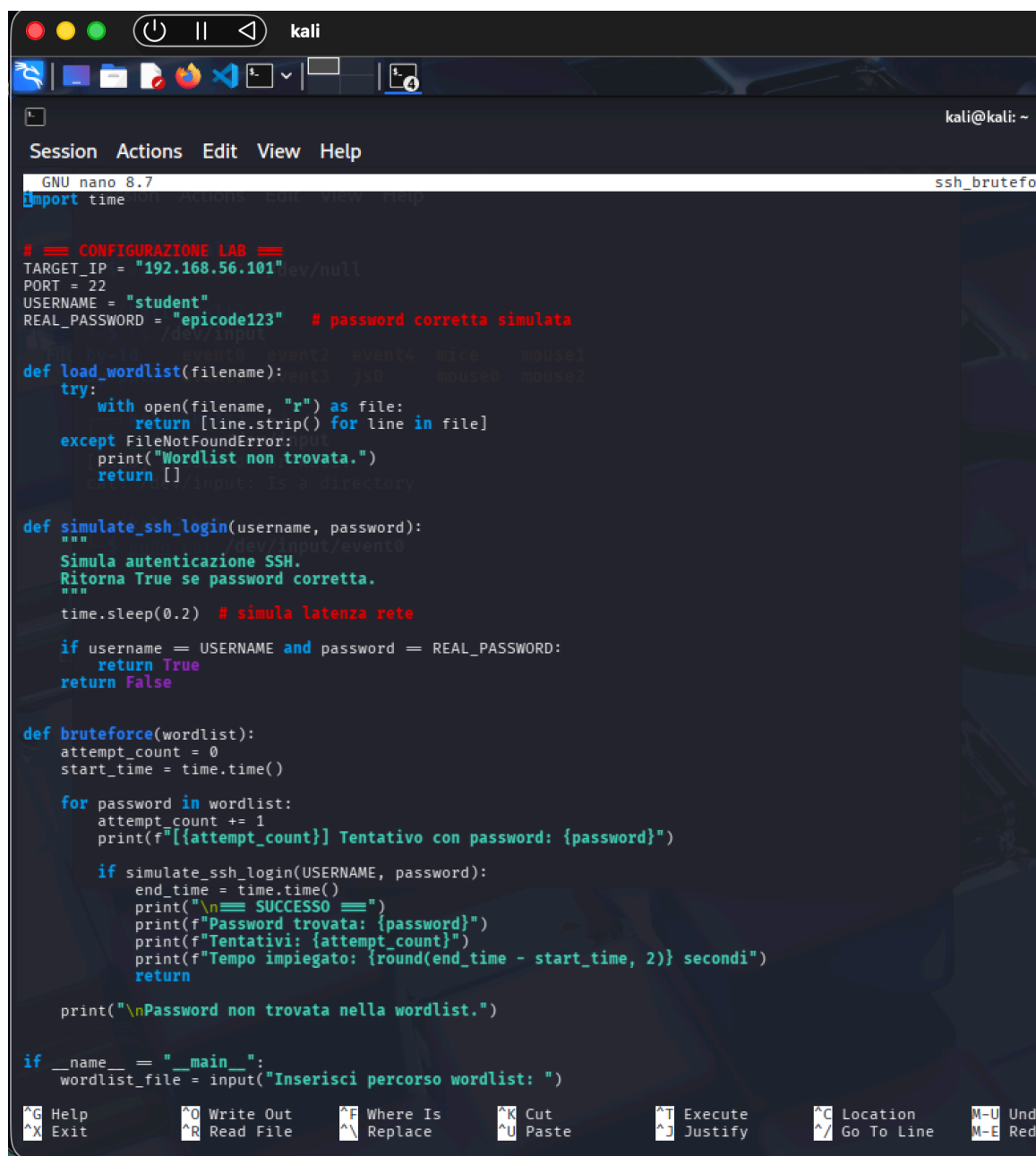
4. Problemi Ricontrati e Troubleshooting

Durante il laboratorio sono stati riscontrati diversi problemi tecnici, tra cui: - IP errato della macchina vittima - Servizio SSH non correttamente avviato - Incompatibilità tra algoritmi SSH legacy (ssh-rsa,ssh-dss) e client moderni La risoluzione è avvenuta tramite verifica della rete, riavvio del servizio SSH e forzatura degli algoritmi legacy necessari per stabilire la connessione.

5. Implementazione dello Script Python

È stato sviluppato uno script Python per simulare un attacco brute force. Lo script carica una wordlist, itera sulle password e verifica la correttezza delle credenziali tramite una funzione di autenticazione simulata. Lo script dimostra la logica del brute force: - Ciclo iterativo sulle password - Conteggio dei tentativi - Rilevamento password corretta Misurazione del tempo di esecuzione

Figura 7.1: Codice Python



```
GNU nano 8.7 ssh_brutefo
import time

# == CONFIGURAZIONE LAB ==
TARGET_IP = "192.168.56.101"
PORT = 22
USERNAME = "student"
REAL_PASSWORD = "epicode123" # password corretta simulata

def load_wordlist(filename):
    try:
        with open(filename, "r") as file:
            return [line.strip() for line in file]
    except FileNotFoundError:
        print("Wordlist non trovata.")
        return []

def simulate_ssh_login(username, password):
    """
    Simula autenticazione SSH.
    Ritorna True se password corretta.
    """
    time.sleep(0.2) # simula latenza rete

    if username == USERNAME and password == REAL_PASSWORD:
        return True
    return False

def bruteforce(wordlist):
    attempt_count = 0
    start_time = time.time()

    for password in wordlist:
        attempt_count += 1
        print(f"[{attempt_count}] Tentativo con password: {password}")

        if simulate_ssh_login(USERNAME, password):
            end_time = time.time()
            print("\n== SUCCESSO ==")
            print(f"Password trovata: {password}")
            print(f"Tentativi: {attempt_count}")
            print(f"Tempo impiegato: {round(end_time - start_time, 2)} secondi")
            return

    print("\nPassword non trovata nella wordlist.")

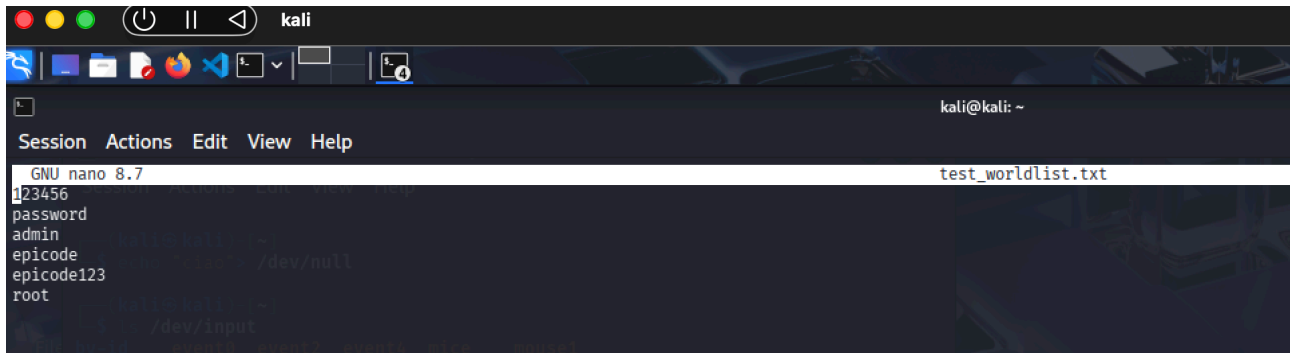
if __name__ == "__main__":
    wordlist_file = input("Inserisci percorso wordlist: ")

    ^G Help      ^O Write Out  ^F Where Is   ^K Cut        ^T Execute
    ^X Exit      ^R Read File  ^_ Replace    ^U Paste      ^J Justify
    ^C Location  ^_ Go To Line M-U Und
    ^M-E Red
```

Lo script Python sviluppato in questo laboratorio ha finalità esclusivamente didattiche. Non effettua una connessione reale al servizio SSH della macchina Metasploitable, ma simula la logica di un attacco brute force. In particolare, lo script: Carica una wordlist da file esterno Itera ciclicamente sulle password Conta il numero di tentativi effettuati Simula un tempo di latenza per imitare una connessione reale Verifica la correttezza delle credenziali tramite una funzione di autenticazione interna Interrompe il ciclo al momento dell'individuazione della password corretta Questa scelta è stata adottata per concentrarsi sulla comprensione della logica algoritmica del brute force, evitando l'uso diretto di librerie di attacco reali (es. Paramiko o strumenti automatici). Durante il laboratorio è stata comunque verificata manualmente la raggiungibilità del servizio SSH sulla macchina Metasploitable e la possibilità di autenticazione, dimostrando che l'ambiente di rete era

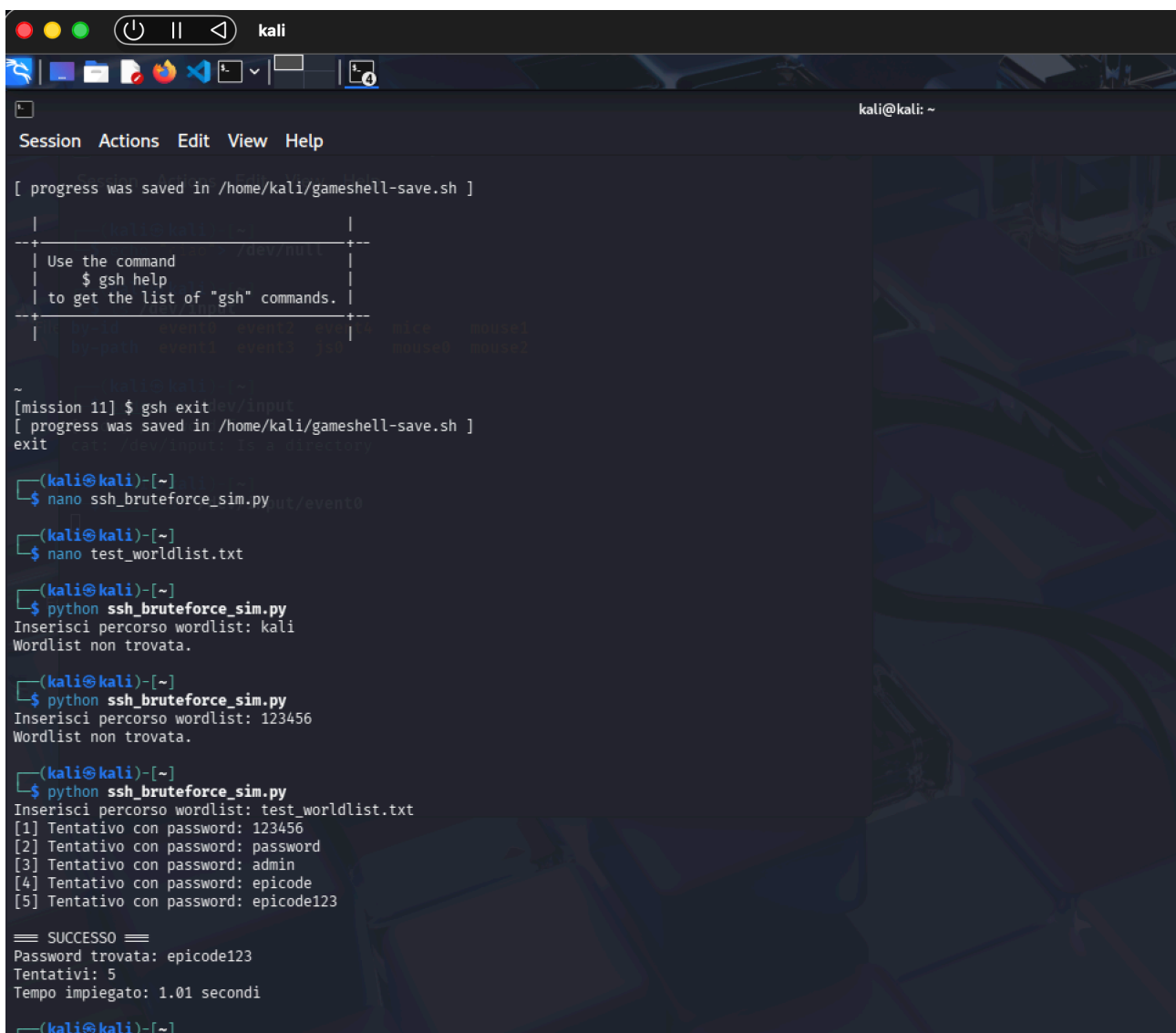
correttamente configurato. L'obiettivo dell'esercizio non era compromettere un sistema reale, ma comprendere: il funzionamento iterativo dell'attacco l'importanza della robustezza delle password le vulnerabilità dei sistemi legacy il concetto di rate limiting e hardening dei servizi.

Figura 7.2: Crerazione Wordlist



```
kali
Session Actions Edit View Help
GNU nano 8.7 test_worldlist.txt
123456
password
admin
epicode
epicode123
root
```

Figura 7.3: Esecuzione attacco Brute Force



```
kali
Session Actions Edit View Help

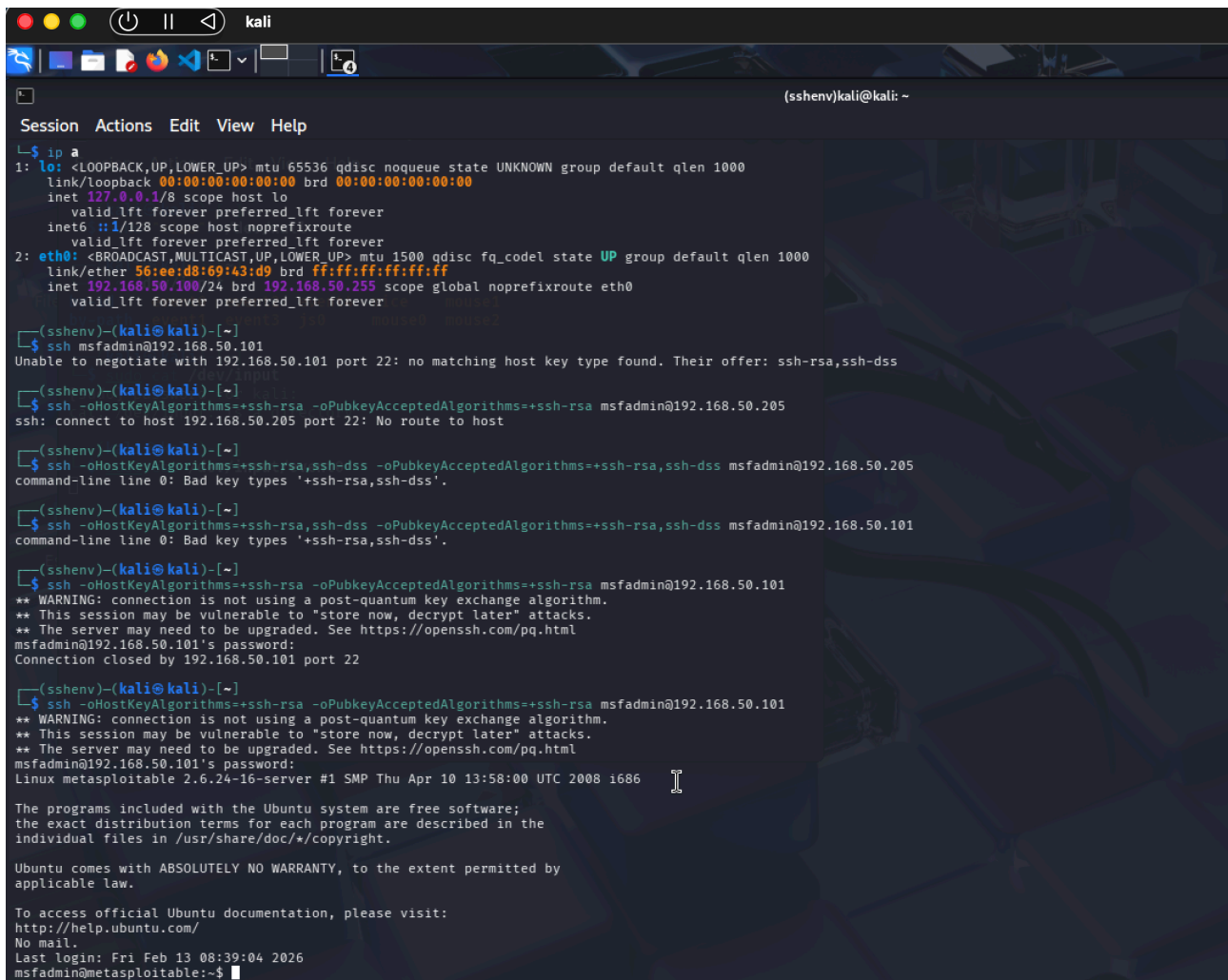
[ progress was saved in /home/kali/gameshell-save.sh ]

~
[mission 11] $ gsh exit /dev/input
[ progress was saved in /home/kali/gameshell-save.sh ]
exit

~
(kali@kali)-[~]
$ nano ssh_bruteforce_sim.py
(kali@kali)-[~]
$ nano test_worldlist.txt
(kali@kali)-[~]
$ python ssh_bruteforce_sim.py
Inserisci percorso wordlist: kali
Wordlist non trovata.
(kali@kali)-[~]
$ python ssh_bruteforce_sim.py
Inserisci percorso wordlist: 123456
Wordlist non trovata.
(kali@kali)-[~]
$ python ssh_bruteforce_sim.py
Inserisci percorso wordlist: test_worldlist.txt
[1] Tentativo con password: 123456
[2] Tentativo con password: password
[3] Tentativo con password: admin
[4] Tentativo con password: epicode
[5] Tentativo con password: epicode123

== SUCCESSO ==
Password trovata: epicode123
Tentativi: 5
Tempo impiegato: 1.01 secondi
(kali@kali)-[~]
```

Figura 7.4: Accesso SSH reale



```
kali
Session Actions Edit View Help
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 56:ee:d8:69:43:d9 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.100/24 brd 192.168.50.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever

(sshehv)-(kali@kali)-[~]
$ ssh msfadmin@192.168.50.101
Unable to negotiate with 192.168.50.101 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(sshehv)-(kali@kali)-[~]
$ ssh -oHostKeyAlgorithms=+ssh-rsa -oPubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.50.205
ssh: connect to host 192.168.50.205 port 22: No route to host

(sshehv)-(kali@kali)-[~]
$ ssh -oHostKeyAlgorithms=+ssh-rsa,ssh-dss -oPubkeyAcceptedAlgorithms=+ssh-rsa,ssh-dss msfadmin@192.168.50.205
command-line line 0: Bad key types '+ssh-rsa,ssh-dss'.

(sshehv)-(kali@kali)-[~]
$ ssh -oHostKeyAlgorithms=+ssh-rsa,ssh-dss -oPubkeyAcceptedAlgorithms=+ssh-rsa,ssh-dss msfadmin@192.168.50.101
command-line line 0: Bad key types '+ssh-rsa,ssh-dss'.

(sshehv)-(kali@kali)-[~]
$ ssh -oHostKeyAlgorithms=+ssh-rsa -oPubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.50.101
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.50.101's password:
Connection closed by 192.168.50.101 port 22

(sshehv)-(kali@kali)-[~]
$ ssh -oHostKeyAlgorithms=+ssh-rsa -oPubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.50.101
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.50.101's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Fri Feb 13 08:39:04 2026
msfadmin@metasploitable:~$
```

8. Analisi di Sicurezza

L'attacco brute force sfrutta password deboli e l'assenza di meccanismi di protezione come il rate limiting. Sistemi legacy come Metasploitable risultano particolarmente vulnerabili. Contromisure raccomandate:

- Disabilitare autenticazione tramite password e usare chiavi SSH.
- Implementare Fail2Ban o sistemi IDS/IPS.
- Applicare policy di password robuste.
- Limitare i tentativi di login.
- Aggiornare costantemente il sistema e i protocolli crittografici.

7. Conclusioni

Il laboratorio ha permesso di comprendere sia gli aspetti pratici che teorici di un attacco brute force su SSH. L'esperienza ha evidenziato l'importanza della corretta configurazione dei servizi di rete e dell'adozione di misure di sicurezza adeguate per prevenire attacchi di autenticazione.

